



Domain 5: Security Operations

Data Handling:

- Create
 - Store
 - Use
 - Share
 - Archive
 - Destroy
-
- Organization keep data for specific time (**Regulations**)
OSHA (Occupational Safety and Health Administration) - 30 years
HIPAA - 10 years
 - **Degaussing** - Process of reducing or eliminating an unwanted magnetic field (or data) stored on tape and disk media.

Data Handling Practices:

- **Classification** - Based on laws, regulations, contracts, or business needs. (Range: Minor → Grave)
- **Labeling**
 - Highly restricted - Major harms like loss of life, injury, or major property damage.
 - Moderately restricted - Disrupt planned activities. (Temporary loss)
 - Low sensitivity - Minor disruptions, delays.
 - Unrestricted public data - No harm if shared.
- **Retention** - Indicates how long an organisation is required to maintain information and assets.
- **Destruction** - To avoid remanence: Overwriting (Zeroing), Shredding, burning or acid etching.

Logging and Monitoring Security Events:

Relevant to being recorded and reviewed include, but is not limited to -

- User IDs
- System activities
- Dates / times of key events (eg. logon and logoff)
- Device and location identity
- System configuration changes

Event Logging Best Practices:

- **Ingress monitoring**
 - Firewalls
 - Gateways
 - Remote authentication servers
 - IDS / IPS Tools
 - SIEM Solution
 - Anti-malware Solution
- **Egress monitoring**
 - E-mail
 - Copy to portable media
 - FTP
 - Posting to Web pages / websites
 - Applications / APIs

Encryption Overview:

- Confidentiality
 - Integrity (Hash function)
 - Encryption system
 - Plaintext
-
- Asymmetric encryption is more secure

Configuration Management:

Ensures that the changes made are authorised and validated.

- Identification
 - Baseline
 - Change control - update process for requesting changes to baseline.
 - Verification and Audit
 - Inventory - complete list of all assets.
 - Updates
 - Patches
-
- The Risks of change

Common Security Policies:

Must support any regulations and contractual obligations of the organization.

- **Data Handling Policy**
- **Passwords Policy**
- **Acceptable Use Policy (AUP) -**
Rules how employees can use company devices.
 - Data access
 - System access
 - Data disclosure
 - Passwords
 - Data retention
 - Internet usage
 - Company device usage
- **Bring Your Own Device (BYOD)**
Guideline for employees who use their personal devices for work puposes.
- **Privacy Policy**
 - PII
 - ePHI - electronic PHI
 - GDPR
 - PIPEDA - Personal Information Protection and Electronic Documents (Canada)
 - HIPAA
 - GLBA - Gramm-Leach-Bliley Act (US)

The organization should also create a public document that explains how private information is used, both internally and externally.

- **Change Management Policy**

Discipline of transitioning from the current state to a future state. It consist of three major activities:

- Deciding to change
- Making the change
- Confirming that the change has been correctly accomplished

Policies will be set according to needs of organization and its vision and mission. Each policy should have penalty in case of non-compliance.

Data Handling Policy Procedures:

- Classify
- Categorize
- Label
- Store
- Encrypt
- Backup
- Destroy

Change Management Components:

- **Documentation**

All major change management practices follow a set of core steps:

- Request for change (RFC)
- Moving through development and testing
- Release to users

Each step is formally managed with decisions documented and logged throughout the process.

- **Approval**

Usually involve reviewing RFCs for completeness, assigning them based on risk, involving stakeholders, allocating resources, approving or rejecting changes, and documenting all decisions.

- **Rollback**

Depending on the change, activities may include scheduling, testing, verifying rollback procedures, implementing, evaluating effectiveness, and documenting the change. Rollback authority is defined in the plan and may be immediate or scheduled later if issues arise.

Security Awareness Training:

- Education
- Training
- Awareness - Attract and engage learner's attention (Issue, concern, problem or need)
- Example - SMS Phishing (Smishing)
- Taking feedback is a best practice.

Passwords:

- **Time needed to crack**
 - 10 numbers - 5 Secs
 - 8 Multiple characters - 35 Days
 - 16 Uppercase, lowercase, special characters - 152,000 years

Hashing:

Demonstrate five main properties

- Useful
- Non-reversible
- Content integrity assurance
- Unique
- Deterministic (Same input will always generate the same hash)

Applications - Digital signatures, message authentication codes, and other forms of authentication.

Variable data input + Hashing algorithm = Fixed bit size data output (the digest)

- Hash digest does not vary according to the size of the message.
- A **checksum** is a fixed-size value generated from. This value acts as a "fingerprint" for the data. (Integrity)

Asymmetric Encryption:

- Also called Public key cryptography.
- User generate pair of keys: Private key (Secret) and Public key (Shared)
- Uses the public key to encrypt data and the private key to decrypt data.
- Much slower than symmetric cryptography.
- Enables the creation of digital signatures, which can be used to verify the authenticity of data. A digital signature is created by encrypting a hash of the data with the sender's private key.
- Scales better.

Symmetric Encryption:

- Also called same, single, shared, secret, session key cryptography.
- Uses single key.
- Key exchange is a challenge.
- Hard to scale.
- Primary uses:
 - Encrypting Bulk data.
 - Encrypt messages traversing communication channels.
 - Streaming large-scale, time sensitive data.

Social Engineering:

- **Phishing**

A broad attack where a scammer sends fake emails to many people, hoping someone will click a malicious link or provide sensitive information.

Spear phishing - Targeted whole company.

- **Vishing**

"Voice phishing," where an attacker calls someone and uses a fake story to trick them into giving away personal data like passwords or credit card numbers.

- **Whaling**

A highly targeted phishing attack aimed at a "big fish," like a CEO or another high-level executive, to trick them into transferring money or revealing company secrets.

- **Quid pro Quo**

An attack where the scammer offers something in exchange for information. It's Latin for "something for something."

- **Pretexting**

The attacker creates a believable but fake story (a pretext) to build trust and convince a victim to do something they shouldn't.

- **Tailgating**

A physical attack where an unauthorized person follows an authorized person into a secure area without using a key or badge.

- **Baiting**

Luring a victim with a tempting offer to trick them into taking an unsafe action, like installing malware or giving up information.

- **False Flag**

An attack where the hacker intentionally misleads investigators to make it look like another person or group was responsible.